Definitely Maybe Encrypted

A combination of malware analysis techniques and unorthodox encryption weaknesses

Difficulty: Medium

Benjamin Poulton

Abertay HackSoc Term 1 CTF 25/26

1 INTRODUCTION

“Known Evil” is a challenge where users have to extract a encrypted ZIP file resource from an EXE file. They must then decrypt the contents of this EXE file, by using the tool “bkcrack” to extract the archive’s keys using a known plaintext.

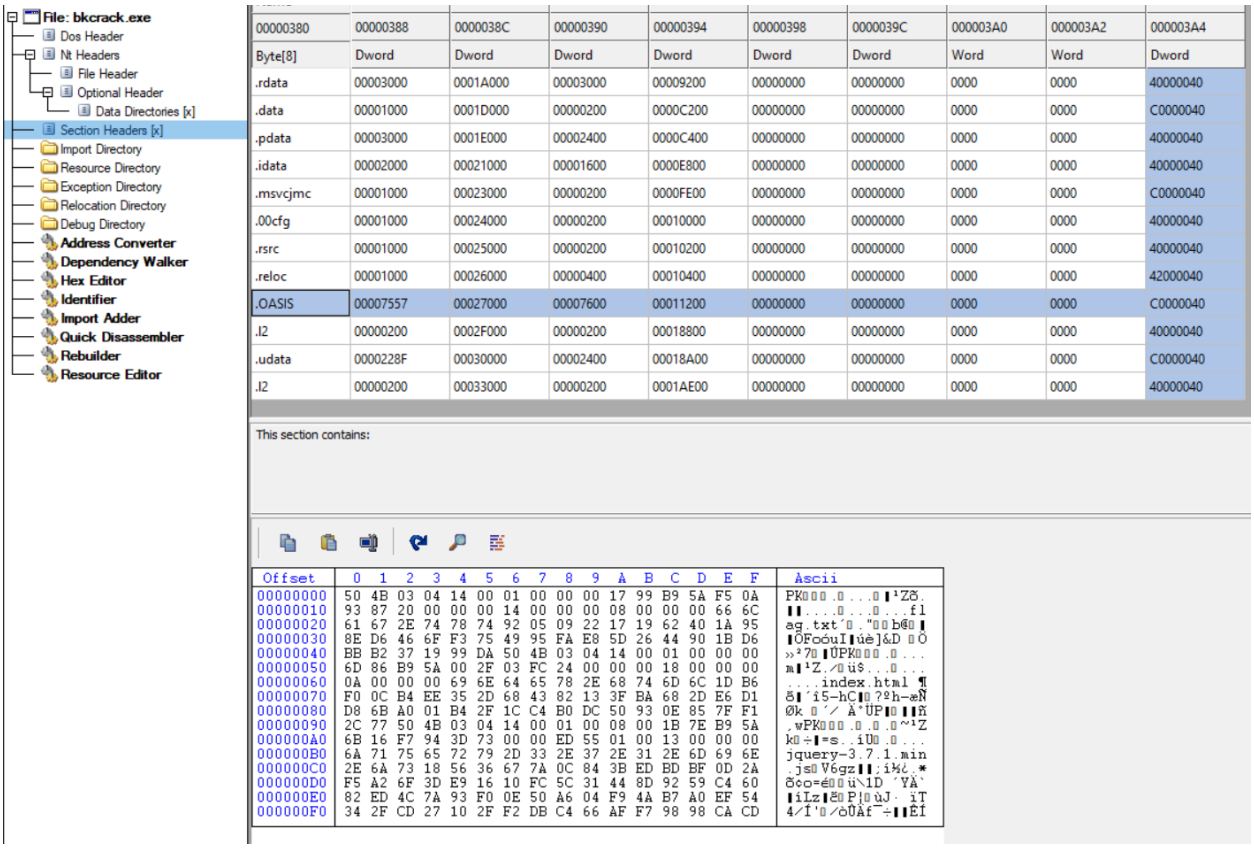
Challenge description

“Discovered this EXE file. I'm sure there's more to it than it seems, and I know I've seen the name before somewhere.”

The user is provided with an EXE file titled bkcrack.exe. (THIS IS NOT THE TOOL NEEDED)

2 SOLUTION

The provided EXE file has a section header titled .OASIS, and checking this shows it starts with the file signature of a zip file. Extracting this resource from the EXE will provide the user with a password protected zip file including the flag, a copy of jquery-3.7.1.min.js, and a placeholder HTML file.



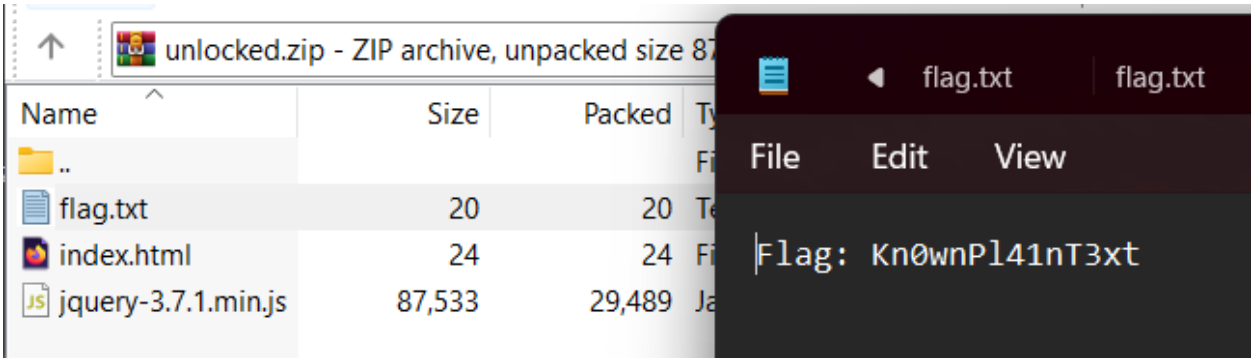
00000380	00000388	0000038C	00000390	00000394	00000398	0000039C	000003A0	000003A2	000003A4
Byte[8]	Dword	Dword	Dword	Dword	Dword	Dword	Word	Word	Dword
.rdata	00003000	0001A000	00003000	00009200	00000000	00000000	0000	0000	40000040
.data	00001000	0001D000	00000200	0000C200	00000000	00000000	0000	0000	C0000040
.pdata	00003000	0001E000	00002400	0000C400	00000000	00000000	0000	0000	40000040
.idata	00002000	00021000	00001600	0000E800	00000000	00000000	0000	0000	40000040
.msvcjmc	00001000	00023000	00000200	0000FE00	00000000	00000000	0000	0000	C0000040
.00cfg	00001000	00024000	00000200	00010000	00000000	00000000	0000	0000	40000040
.rsrc	00001000	00025000	00000200	00010200	00000000	00000000	0000	0000	40000040
.reloc	00001000	00026000	00000400	00010400	00000000	00000000	0000	0000	42000040
.OASIS	00007557	00027000	00007600	00011200	00000000	00000000	0000	0000	C0000040
.I2	00000200	0002F000	00000200	00018800	00000000	00000000	0000	0000	40000040
.udata	0000228F	00030000	00002400	00018A00	00000000	00000000	0000	0000	C0000040
.I2	00000200	00033000	00000200	0001AE00	00000000	00000000	0000	0000	40000040

Offset	0 1 2 3 4 5 6 7 8 9 A B C D E F	Ascii
00000000	50 4B 03 04 14 00 01 00 00 00 17 99 B9 5A F5 0A	PK□□□.□...□▌¹Z□.
00000010	93 87 20 00 00 00 14 00 00 00 08 00 00 00 66 6C	▌▌....□...□...fl
00000020	61 67 2E 74 78 74 92 05 09 22 17 19 62 40 1A 95	ag.txt´□."□□b@□▌
00000030	8E D6 46 6F F3 75 49 95 FA E8 5D 26 44 90 1B D6	▌ÖFoóuI▌úè]&D □Ö
00000040	BB B2 37 19 99 DA 50 4B 03 04 14 00 01 00 00 00	»²7□▌ÚPK□□□.□...
00000050	6D 86 B9 5A 00 2F 03 FC 24 00 00 00 18 00 00 00	m▌¹Z./□ü$...□...
00000060	0A 00 00 00 69 6E 64 65 78 2E 68 74 6D 6C 1D B6	....index.html ¶
00000070	F0 0C B4 EE 35 2D 68 43 82 13 3F BA 68 2D E6 D1	ð▌´i5-hC▌?ºh-æÑ
00000080	D8 6B A0 01 B4 2F 1C C4 B0 DC 50 93 0E 85 7F F1	Øk □´/ Ä°ÜP▌□▌▌ñ
00000090	2C 77 50 4B 03 04 14 00 01 00 08 00 1B 7E B9 5A	,wPK□□□.□.□.□~¹Z
000000A0	6B 16 F7 94 3D 73 00 00 ED 55 01 00 13 00 00 00	k□÷▌=s..íU□.□...
000000B0	6A 71 75 65 72 79 2D 33 2E 37 2E 31 2E 6D 69 6E	jquery-3.7.1.min
000000C0	2E 6A 73 18 56 36 67 7A 0C 84 3B ED BD BF 0D 2A	.js□V6gz▌▌;i¼¿.*
000000D0	F5 A2 6F 3D E9 16 10 FC 5C 31 44 8D 92 59 C4 60	õco=é□□ü\1D´YÄ`
000000E0	82 ED 4C 7A 93 F0 0E 50 A6 04 F9 4A B7 A0 EF 54	▌iLz▌ð□P¦□ùJ· iT
000000F0	34 2F CD 27 10 2F F2 DB C4 66 AF F7 98 98 CA CD	4/Í'□/òÛÄf¯÷▌▌ÊÍ

The zip file contains a base64 encoded comment, that simply states the ZIP archive was created using 7zip 24.09, and as the archive contains a well known file (jquery-3.7.1.min.js), it is possible to perform a known plaintext attack on the ZIP file. This requires the user to create an unencrypted zip using the same compression method (7zip 24.09, deflate, normal compression), before using bkcrack to generate the key used.

```
C:\Users\Ben\Downloads\CTF\bkcrack-1.7.1-win64>bkcrack.exe -C CTF.zip -c jquery-3.7.1.min.js -P jquery-3.7.1.min.js.zip
-p jquery-3.7.1.min.js
bkcrack 1.7.1 - 2024-12-21
[23:54:44] Z reduction using 29482 bytes of known plaintext
83.5 % (24632 / 29482)
[23:54:45] Attack on 150 Z values at index 5455
Keys: db6f6794 e9a0e667 84232d49
100.0 % (150 / 150)
Found a solution. Stopping.
[23:54:45] Keys
db6f6794 e9a0e667 84232d49

C:\Users\Ben\Downloads\CTF\bkcrack-1.7.1-win64>
```

this key can then be used to generate a new archive with the same files, but without any encryption, meaning the flag can be viewed.

```
C:\Users\Ben\Downloads\CTF\bkcrack-1.7.1-win64>bkcrack.exe -C CTF.zip -k db6f6794 e9a0e667 84232d49 -D unlocked.zip
bkcrack 1.7.1 - 2024-12-21
[23:56:32] Writing decrypted archive unlocked.zip
100.0 % (3 / 3)
```